

## README — KIT DE ENCUESTA SAMM + GQM + PRAGMATIC

### Guía de Implementación del Programa de Indicadores de Ciberseguridad

**Versión:** 1.0 | **Fecha:** Enero 2026

**Público objetivo:** CISOs, Equipos de Medición, Consultores, Investigadores

**Duración estimada de lectura:** 30 minutos

#### 1. BIENVENIDA AL KIT

Has descargado el **Kit Completo de Indicadores de Ciberseguridad** basado en:

- **GQM** (Goal–Question–Metric) — Metodología de Harvard/NASA
- **GQM+Strategies** — Extensión de Fraunhofer (alineación negocio-técnica)
- **PRAGMATIC** — 9 criterios de calidad de métricas (Brotby, Hinson, Glasgow)
- **OWASP SAMM v2** — Framework de madurez de seguridad de software
- **Regulación española 2025-2026** — NIS2, CRA, GDPR, ENS, DORA

Este README te guiará para implementar el kit sin perder la perspectiva estratégica.

#### 2. CONTENIDOS DEL KIT

El kit consta de **6 documentos complementarios**:

##### **Documento A: Marco Integrativo GQM+PRAGMATIC (marco\_gqm\_pragmatic.md)**

- Extensión: 70+ páginas
- Contenido:
- Objetivos nacionales españoles (NIS2, CRA, GDPR, ENS, DORA)
- Estructura 4-niveles: Nacional → Goal → Question → Metric
- 50+ métricas técnicas específicas por dominio SAMM
- Metodología PRAGMATIC (9 criterios)
- Roadmap de implementación
- Para quién: Arquitectos, CISOs, investigadores (lectura profunda)

##### **Documento B: Matriz de Evaluación PRAGMATIC Completa (matriz\_pragmatic\_evaluacion.md)**

- Extensión: 50+ páginas
- Contenido:
- Evaluación detallada de 30+ métricas OWASP SAMM
- Scoring 1-5 en 9 criterios PRAGMATIC
- Rankings de métricas (Top 10, Top 15)
- Recomendaciones: Adoptar / Adoptar con cuidado / Evitar
- Portfolio recomendado por fase (Quick Wins → Consolidation → Expansion)
- Para quién: Measurement teams, governance councils (decisión de qué implementar)

#### **Documento C: Mapeo Preguntas → Normativa (mapeo\_preguntas\_normativa.md)**

- Extensión: 40+ páginas
- Contenido:
- 29 preguntas GQM mapeadas a artículos normativos específicos
- Tabla por dominio SAMM
- Cómo cada pregunta contribuye a cumplimiento regulatorio
- Evidencias técnicas requeridas
- Umbrales de cumplimiento
- Para quién: Compliance officers, auditores, CISOs (demostrabilidad regulatoria)

#### **Documento D: Plantilla Excel IGM y ROI (plantilla\_excel\_igm\_roi.md)**

- Extensión: 30+ páginas
- Contenido:
- Estructura de 7 hojas Excel: CONFIG, METRICAS, PRAGMATIC, DOMINIO, IGM\_GLOBAL, COSTES, ROI
- Fórmulas detalladas (normalización, cálculos ponderados)
- Métodos para calcular IGM (Índice Global de Madurez)
- Cálculo de ROI (3 años, VAN, TIR)
- Ejemplos numéricos completos
- Para quién: Finance, measurement teams (quantificación de madurez y ROI)

#### **Documento E: Plantilla Reporte Ejecutivo PowerPoint (plantilla\_reporte\_ejecutivo\_ppt.md)**

- Extensión: 25+ páginas
- Contenido:
- Estructura de 14 diapositivas para presentación a Board
- Contenidos detallados por slide
- Gráficos y visualizaciones sugeridas
- Notas para el ponente
- Anticipated Q&A
- Para quién: CISOs, presentadores a Consejo (comunicación ejecutiva)

#### **Documento F: Este README (README\_kit\_encuesta.md)**

- Guía de uso del kit completo
- Workflow recomendado
- FAQ
- Soporte

### **3. PROPÓSITO DEL KIT**

Este kit responde a:

**"¿Cómo puedo medir la madurez de ciberseguridad de mi organización de forma rigurosa, defendible y alineada con regulación española?"**

## Beneficios entregados

### ✓ Rigurosidad académica

- Basado en 80+ fuentes peer-reviewed y oficiales
- Metodologías de NASA/Harvard + Fraunhofer + instituciones de medición

### ✓ Contexto nacional explícito

- Objetivos NIS2, CRA, GDPR, ENS, DORA específicos para España
- Plazos y hitos regulatorios 2025-2026

### ✓ Trazabilidad completa

- Cada métrica traceable a artículo regulatorio
- Auditable, no opinión

### ✓ Operacionalidad

- Implementable en 12 meses sin transformación radical
- Portfolio incremental (Quick Wins primero)

### ✓ Multiaudiencia

- Para CISO (gobernanza)
- Para DevSecOps (implementación)
- Para Finance (ROI)
- Para Board (decisión de inversión)

## 4. FLUJO RECOMENDADO DE USO

### FASE 0: COMPRENSIÓN (Semana 1)

#### Paso 1A — Lee esta sección del README (30 min)

- Contexto del kit
- Qué es GQM, PRAGMATIC, SAMM
- Roadmap de uso

#### Paso 1B — Lee Síntesis Ejecutiva del Marco (45 min)

- Secciones: Objetivos nacionales, arquitectura GQM 4-niveles, ejemplos
- Objetivo: Entender cómo regulación — goals — metrics

#### Paso 1C — Visualiza Matriz de Evaluación PRAGMATIC (30 min)

- Hoja con rankings de métricas
- Entender qué significa "Score PRAGMATIC 95.6%"
- Identificar top 5 métricas

### FASE 1: DISEÑO (Semanas 2-3)

#### Paso 2A — Define alcance de evaluación

- ¿A cuáles dominios SAMM aplicas? (todos vs. subset)

- ¿Cuáles roles stakeholders participan? (CISO, architects, devs, ops, security team)
- ¿Cuál es plazo de levantamiento? (4 semanas típicamente)

### **Paso 2B — Selecciona top 10-15 métricas**

- Filtro 1: PRAGMATIC score > 80% (calidad)
- Filtro 2: Alineación a regulación crítica (NIS2, CRA)
- Filtro 3: Capacidad de recopilación (¿tienes datos hoy?)
- Referencia: Documento B (Matriz PRAGMATIC)

### **Paso 2C — Diseña/adapta encuesta**

- Usar preguntas GQM del Documento A como plantilla
- Para cada pregunta, crear 3-5 ítems de cuestionario específicos
- Plataforma: Google Forms, Qualtrics, SurveyMonkey, etc.
- Mencionar Q-ID en cada ítem (para trazabilidad a normativa)

### **Paso 2D — Valida con stakeholders**

- Sesión con CISO: ¿Qué métricas importan para regulación/negocio?
- Sesión con team de medición: ¿Podemos recopilar estos datos?
- Sesión con arquitectos: ¿Interpretación de preguntas es clara?

## **FASE 2: RECOPIACIÓN (Semanas 4-6)**

### **Paso 3A — Lanza encuesta a roles clave**

- CISO y directores de seguridad (1-2)
- Arquitectos de software (3-5)
- DevSecOps leads (2-3)
- Responsables SIEM/SOC (1-2)
- QA leads (1-2)
- Compliance/audit (1)

Objetivo: 10-15 respondentes de backgrounds distintos (triangulación)

### **Paso 3B — Recopila datos técnicos en paralelo**

- SAST integration: logs de CI/CD
- MTTD: logs de SIEM/SOC
- MTTR: defect tracker
- Phishing click-rate: plataforma simulación
- Scan coverage: scanner reports
- Patch compliance: patch management tool

### **Paso 3C — Validación de datos**

- Comparar respuestas de encuesta con datos técnicos
- Resolver discrepancias (¿percepción vs. realidad?)
- Documentar fuentes de datos por métrica

### FASE 3: ANÁLISIS (Semana 7)

#### Paso 4A — Normaliza datos a escala 0-1

- Usar fórmulas de Documento D (Excel IGM/ROI)
- Para cada métrica: Valor actual normalizado
- Ejemplo: SAST 80%/100% = 0.8

#### Paso 4B — Calcula scores por dominio

- Suma normalizada por dominio SAMM (GOV, DES, IMP, VER, OPS, TRAIN)
- Aplica pesos dentro dominio (ej: si hay 4 métricas en IMP, peso = 1/4 cada una)

#### Paso 4C — Calcula IGM Global

- Usa fórmula maestra (documento D): SUMAR.PRODUCTO(scores dominio; pesos globales)
- Resultado: IGM 0-100 (ej: 63)

#### Paso 4D — Análisis de brechas

- Compara IGM actual vs. objetivo (ej: 63 vs. 80)
- Identifica top 3 dominios débiles (% más bajo)
- Linkea a riesgo operacional y regulatorio

### FASE 4: REPORTING Y DECISIÓN (Semanas 8-9)

#### Paso 5A — Genera reportes por audiencia

##### Para CISO/Governance:

- IGM actual vs. meta
- Top 3 brechas + impacto
- Roadmap 12 meses propuesto

##### Para Finance/Board:

- Caso de negocio (iniciativas + ROI)
- Payback period (típicamente 2-3 años)
- Comparison: costo incidente vs. costo prevention

##### Para technical teams (DevSecOps, SOC, etc.):

- Qué métrica impacta tu área
- Qué acciones concretas (herramientas, procesos)
- Timeline de implementación

#### Paso 5B — Valida resultados con stakeholders

- Sesión de validación con CISO
- Sesión técnica con arquitectos/devops
- ¿Resultados "suenan verdaderos"?
- Ajusta si hay desviaciones grandes

### Paso 5C — Presenta a Board (Documento E)

- Usa plantilla PowerPoint (14 slides)
- 45 min presentación + Q&A
- Goal: obtener aprobación de roadmap + presupuesto

## FASE 5: IMPLEMENTACIÓN (Meses 2-12)

### Paso 6A — Quick Wins (Q1)

- 5 métricas, 3 semanas, €10k
- Ejemplo: SAST, MTTD, Phishing sim, Scan coverage, Build gates
- Establecer baseline de cada métrica

### Paso 6B — Governance de métricas

- Owner por métrica (responsable reporte)
- Escalation criteria (ej: si MTTD > 8h → alert)
- Review cadence (semanal/mensual/trimestral)

### Paso 6C — Consolidation (Q2)

- +4 métricas
- €15k adicional
- Expandir iniciativas de Q1

### Paso 6D — Expansion (Q3-Q4)

- Full suite ~12-15 métricas core
- €60k-80k total presupuesto anual
- Optimización y roadmap para 2027

## 5. MAPAS DE REFERENCIA RÁPIDA

¿Cuál documento leer según tu rol?

| Rol                | Documento Primario      | Lectura (min) | Propósito                                   |
|--------------------|-------------------------|---------------|---------------------------------------------|
| CISO               | A (Marco) + E (PPT)     | 120+30        | Entender marco + comunicar                  |
| Measurement Lead   | D (Excel) + B (Matriz)  | 90+60         | Implementar cálculos + seleccionar métricas |
| Compliance Officer | C (Mapeo normativo)     | 90            | Trazabilidad regulatoria                    |
| DevSecOps          | A (Sección metrics IMP) | 45            | Entender qué se mide en tu dominio          |
| Investigador       | A (completo)            | 180+          | Profundidad teórica                         |
| Consultor          | B (Matriz) + C (Mapeo)  | 120           | Adaptar a cliente                           |

## Atajos por pregunta frecuente

### P1: "¿Cuál es la métrica más importante?"

- Documento B, Slide 6 (Top 10 PRAGMATIC scores)
- Respuesta: SAST Integration Coverage (95.6%) o MTTD Mean (91.1%)

### P2: "¿Cómo sé si estoy cumpliendo NIS2?"

- Documento C (Mapeo preguntas → normativa)
- Localiza NIS2 Art. 21.2 → identifica preguntas asociadas → valida respuestas

### P3: "¿Cuánto cuesta implementar esto?"

- Documento D (Excel)
- Inicialmente: ~€100-150k anual (herramientas + personal)

### P4: "¿Cuánto tarda?"

- Este README, Fase 1-5
- Evaluación inicial: 8-9 semanas
- Full implementation: 12 meses

### P5: "¿Puedo usar solo parte del kit?"

- Sí. Documento A es modular por dominio SAMM.
- Si solo necesitas Verificación: Lee solo dominio VER de Doc A.

## 6. PREGUNTAS FRECUENTES (FAQ)

### F1: ¿Necesito usar TODOS los documentos?

**R:** No. Depende de tu caso de uso:

- Si quieres entender el marco: A + E
- Si quieres implementar métricas: B + D
- Si quieres cumplir regulación: C
- Si quieres todo: A+B+C+D+E

### F2: ¿Puedo adaptar/customizar el kit?

**R:** Totalmente recomendado. El kit es plantilla, no dogma.

- Ajusta pesos por dominio según tu contexto
- Añade/elimina métricas según regulación específica
- Adapta roadmap a tu velocidad de ejecución

### F3: ¿Necesito ser experto técnico para usarlo?

**R:** Ayuda, pero no obligatorio.

- Documento A/B: Pueden leerlo non-techy (alto nivel explicado)
- Documento D (Excel): Necesitas entender fórmulas básicas
- Documento C: Compliance-focused, relativamente non-technical

#### F4: ¿Cómo presento esto a mi Board?

**R:** Usa Documento E (PPT template).

- 14 slides, 45 min + Q&A
- Enfatiza: IGM actual vs. objetivo + ROI
- Anticipa "¿Por qué gastar €300k si tenemos firewall?"

#### F5: ¿Cada cuánto debo re-evaluar?

**R:** Recomendación: Anualmente, con revisiones trimestrales.

- Trimestrales: Actualizar valores de métricas operacionales (MTTD, MTTR, Phishing)
- Anuales: Full re-evaluation + revisión PRAGMATIC scores (¿siguen siendo relevantes?)

#### F6: ¿Qué herramientas necesito?

**R:** Mínimo:

- Excel o Google Sheets (para IGM/ROI)
- Google Forms o Qualtrics (para encuesta)
- SIEM/scanner tools existentes (para datos técnicos)

#### F7: ¿Puedo compartir este kit?

**R:** Completamente. Los documentos son:

- Bajo licencia CC-BY (atribución; libre distribución)
- Diseñados para ser compartidos en comunidad de seguridad

## 7. SOPORTE Y EXTENSIONES

#### Documentos complementarios que podrías desarrollar

- Kit de encuesta Excel (cuestionario parametrizado)
- Guía de formación para measurement teams (1 día)
- Benchmark database (cómo se compara con industria)
- Integration con Jira/GRC tools
- Dashboard automatizado (Power BI / Tableau)

#### Contacto / Comunidad

Preguntas o feedback:

- Comunidad OWASP SAMM: <https://owasp samm.org>
- Foro de GQM: academia.edu (buscar "GQM Basili")
- FIRST (Forum of Incident Response and Security Teams): <https://www.first.org> (EPSS)

## 8. RESUMEN EN 2 MINUTOS

El kit te proporciona un **sistema riguroso, trazable y operacional** para:



1. Medir madurez de seguridad usando 50+ métricas SAMM
2. Alinear cada métrica a regulación española (NIS2, CRA, GDPR, ENS, DORA)
3. Calcular IGM (Índice Global Madurez) y ROI de inversiones
4. Comunicar a Board con datos defendibles

**Timeline:** 8-9 semanas para evaluación inicial; 12 meses para full implementation.

**Costo:** ~€100-150k/año (herramientas + FTE medición).

**ROI:** 40% promedio; payback 2-3 años.

**Beneficio cualitativo:** Cumplimiento regulatorio demostrable + reducción riesgos material + alineación negocio-seguridad.

## CONCLUSIÓN

Bienvenido al futuro de la medición de ciberseguridad basada en datos.

No es perfecto. Pero es riguroso, auditable y alineado con regulación.

**¿Listo para comenzar? Empieza por el Paso 1A de la Fase 0.**

### Versionado:

- v1.0 (Enero 2026): Lanzamiento inicial
- Próximas versiones: Basadas en feedback de comunidad + evolución regulatoria

### Atribuciones:

- GQM: Victor Basili, NASA/University of Maryland
- GQM+Strategies: Fraunhofer IESE
- PRAGMATIC: Brotby, Hinson, Glasgow, University of Western Ontario
- OWASP SAMM v2: OWASP Foundation
- Regulación: UE, España, organismos de normalización